

MEDIROZA GENERAL HOSPITAL

Penetration Testing Report

Black-Box Web Application Security Assessment

Engagement Information	Details
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Assessment Type	Black-Box Web Application Penetration Test
Program	Networkwalks Cybersecurity Internship
Batch / Week	B083 / Week 4
Duration	5 Days
Scope	Authorized target domain only
Prepared By	Pritesh Kalsariya

CONFIDENTIALITY NOTICE

This report was prepared for an authorized educational security assessment. It contains descriptions of security testing activities and should be handled according to the rules of the engagement. Sensitive patient, credential, password, and confidential organizational information is intentionally omitted from this document.

1. Executive Summary

A black-box penetration test was conducted against the authorized Mediroza General Hospital training environment as part of the Networkwalks Cybersecurity Internship, Batch B083, Week 4. The assessment followed a staged approach beginning with reconnaissance and web application analysis, followed by controlled authentication testing, retrieval of protected patient reports, offline analysis of the recovered files, and investigation of additional exposed resources.

The assessment identified security weaknesses that, in combination, enabled unauthorized access to restricted patient laboratory reports and subsequent discovery of sensitive organizational information. The principal technical issues documented in this report are an authentication-related SQL injection, exposure of a database backup, weak protection of encrypted PDF reports, directory/resource exposure, and information disclosure through robots.txt.

The engagement successfully completed all four project milestones. Evidence was collected throughout the assessment and is referenced in the relevant sections below. The original 14

screenshots are not embedded in this Word report; instead, each is referenced by its evidence filename and described in text.

2. Engagement Scope and Rules

Item	Details
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Type	Black-box penetration test
Duration	5 days
Scope	Target domain only
Social engineering	Out of scope
Denial of service	Out of scope
Authorization	Written authorization provided for the controlled training environment

Testing was limited to the authorized target and was performed for educational purposes. No claims in this report should be interpreted as authorization to test unrelated systems.

3. Assessment Objectives

Milestone	Objective	Outcome
M1 – Initial Access	Gain access to the restricted area and retrieve three confidential patient PDF laboratory reports.	Completed
M2 – Data Extraction	Recover the contents of all three encrypted PDF reports.	Completed
M3 – Critical Data Exposure	Identify exposed employee salary and shareholder information.	Completed
M4 – Reporting	Document the assessment, evidence, risks, and remediation recommendations.	Completed

4. Methodology

The assessment used a phased black-box methodology. The workflow was designed to minimize unnecessary activity while validating each finding with evidence.

- Reconnaissance and attack-surface discovery
- Web technology and security-control identification
- Authentication and input-handling analysis
- Controlled exploitation and restricted-area access
- Protected document acquisition and offline password recovery
- Web resource and directory analysis

- Database backup discovery and content analysis
- Evidence collection, impact assessment, and remediation planning

5. Tools and Technologies

Category	Tools / Techniques
Reconnaissance	WHOIS, NSLookup, WhatWeb, WAFW00F, DNSRecon
Web Analysis	Browser, Developer Tools, source-code analysis
Exploitation	SQL injection testing
File Analysis	PDF analysis and password-recovery tools
Information Discovery	robots.txt analysis, directory listing analysis, backup-file analysis
Evidence	Screenshots, retrieved files, command output
Operating Environment	Kali Linux

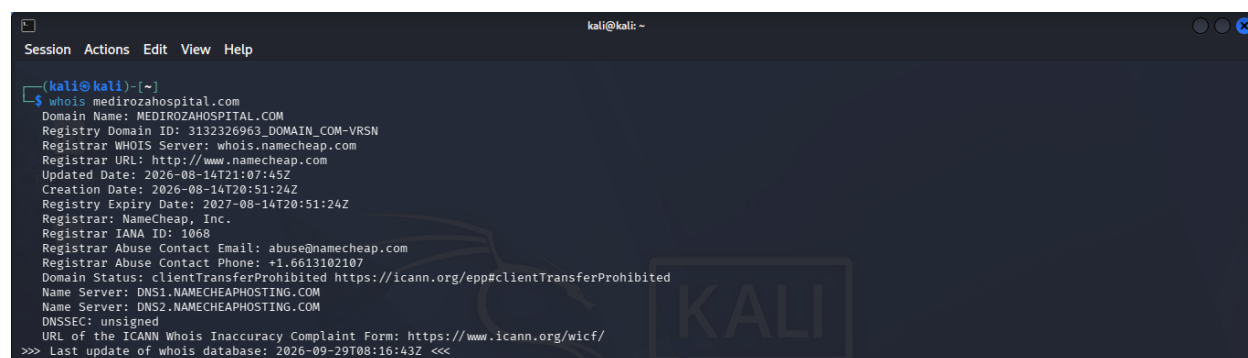
6. Milestone 1 – Initial Access

6.1 Reconnaissance

Initial reconnaissance was performed to understand the target's publicly observable infrastructure, DNS configuration, technologies, and apparent web protection mechanisms. The objective was to identify useful attack-surface information without moving outside the authorized domain.

Evidence 01:

WHOIS reconnaissance and domain-registration information review.



```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ whois medirozahospital.com
Domain Name: MEDIROZAHOSPITAL.COM
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2026-08-14T21:07:45Z
Creation Date: 2026-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-09-29T08:16:43Z <<<

```

Evidence 02:

NSLookup review of DNS and nameserver information.

```
kali@kali: ~  
$ nslookup medirozahospital.com  
Server:      8.8.8.8  
Address:     8.8.8.8#53  
  
Non-authoritative answer:  
Name:   medirozahospital.com  
Address: 199.188.201.16
```

Evidence 03:

Technology fingerprinting of the web application using WhatWeb.

```
kali@kali: ~  
$ whatweb medirozahospital.com  
http://medirozahospital.com [301 Moved Permanently] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, RedirectLocation[https://medirozahospital.com/], Title[301 Moved Permanently][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]  
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]  
https://medirozahospital.com/ [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]
```

Evidence 04:

WAF/security-control detection using WAFW00F.

```
kali@kali: ~  
$ wafw00f medirozahospital.com  
  
W00F!  
404 Hack Not Found  
405 Not Allowed  
403 Forbidden  
502 Bad Gateway  
500 Internal Error  
  
~ WAFW00F : v2.4.2 ~  
The Web Application Firewall Fingerprinting Toolkit  
[*] Checking https://medirozahospital.com  
[+] Generic Detection results:  
[-] No WAF detected by the generic detection  
[-] Number of requests: 7
```

Evidence 05:

DNS enumeration using DNSRecon.

```
kali@kali: ~  
Session Actions Edit View Help  
[kali@kali] ~  
$ dnsrecon -d medirozahospital.com 2>&1  
2026-09-29T04:45:23.257362-0400 INFO Starting enumeration for domain: medirozahospital.com  
2026-09-29T04:45:23.258450-0400 INFO std: Performing General Enumeration against: medirozahospital.com ...  
2026-09-29T04:45:23.608101-0400 ERROR No answer for DNSSEC query for medirozahospital.com  
2026-09-29T04:45:23.725438-0400 INFO SOA dns1.namecheaphosting.com 156.154.132.200  
2026-09-29T04:45:23.725976-0400 INFO SOA dns1.namecheaphosting.com 2610:al:1024::200  
2026-09-29T04:45:23.873922-0400 INFO NS dns1.namecheaphosting.com 156.154.132.200  
2026-09-29T04:45:23.928200-0400 INFO Bind Version for 156.154.132.200 Nameserver"  
2026-09-29T04:45:23.929462-0400 INFO NS dns1.namecheaphosting.com 2610:al:1024::200  
2026-09-29T04:45:23.931578-0400 INFO NS dns2.namecheaphosting.com 156.154.133.200  
2026-09-29T04:45:23.984652-0400 INFO Bind Version for 156.154.133.200 Nameserver"  
2026-09-29T04:45:23.985323-0400 INFO NS dns2.namecheaphosting.com 2610:al:1025::200  
2026-09-29T04:45:24.255113-0400 INFO MX mx2-hosting.jellyfish.systems 162.255.118.29  
2026-09-29T04:45:24.255841-0400 INFO MX mx3-hosting.jellyfish.systems 162.255.118.13  
2026-09-29T04:45:24.256534-0400 INFO MX mx1-hosting.jellyfish.systems 162.255.118.28  
2026-09-29T04:45:24.388835-0400 INFO A medirozahospital.com 199.188.201.16  
2026-09-29T04:45:24.661657-0400 INFO TXT medirozahospital.com v=spf1 +a +mx +ip4:199.188.201.7 +ip4:199.188.201.38 include:spf.web-hosting.com ~all  
2026-09-29T04:45:24.663149-0400 INFO TXT _dmarc.medirozahospital.com v=DMARC1; p=none;  
2026-09-29T04:45:24.778582-0400 INFO Enumerating SRV Records
```

6.2 Authentication and Source-Code Analysis

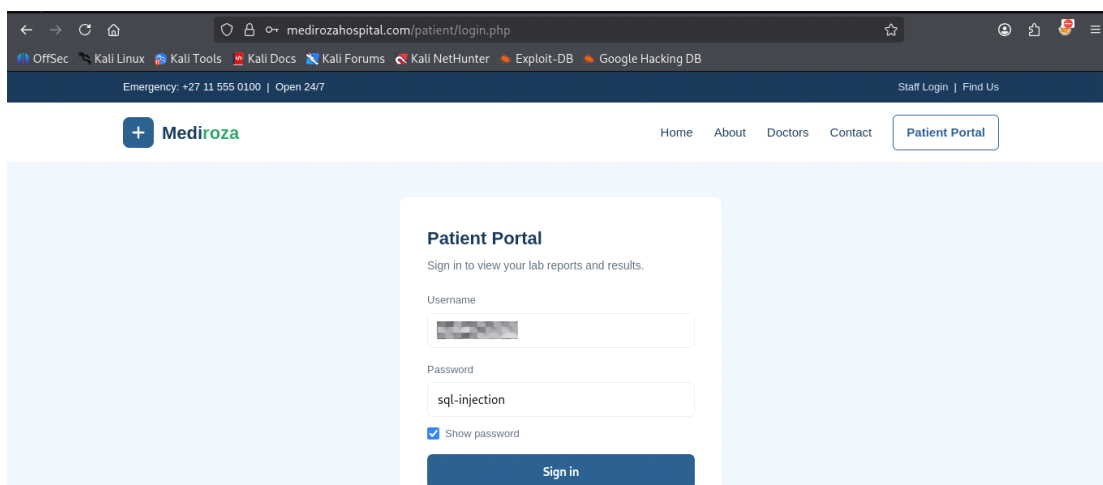
The application login functionality was then examined. The login page source was reviewed to understand the client-side implementation and identify clues about the server-side authentication workflow.

Evidence 06: Login source-code analysis.

```
33 <div class="auth-wrap">  
34 <div class="auth-card">  
35 <h2>Patient Portal</h2>  
36 <p class="sub">Sign in to view your lab reports and results.</p>  
37 <form method="POST" action="/login.php">  
38 <div class="field">  
39 <label for="username">Username</label>  
40 <input type="text" id="username" name="username" autocomplete="off">  
41 </div>  
42 <div class="field">  
43 <label for="password">Password</label>  
44 <input type="password" id="password" name="password" autocomplete="off">  
45 <label class="show-pass">  
46 <input type="checkbox" onclick="var p=document.getElementById('password');p.type=this.checked?'text':'password'"> Show password  
47 </label>  
48 </div>  
49 <button class="btn-submit" type="submit">Sign in</button>  
50 </form>  
51 </div>  
52 </div>
```

Subsequent testing of the authentication mechanism identified SQL injection behavior. The issue was validated through controlled testing and resulted in unauthorized access to the restricted application area.

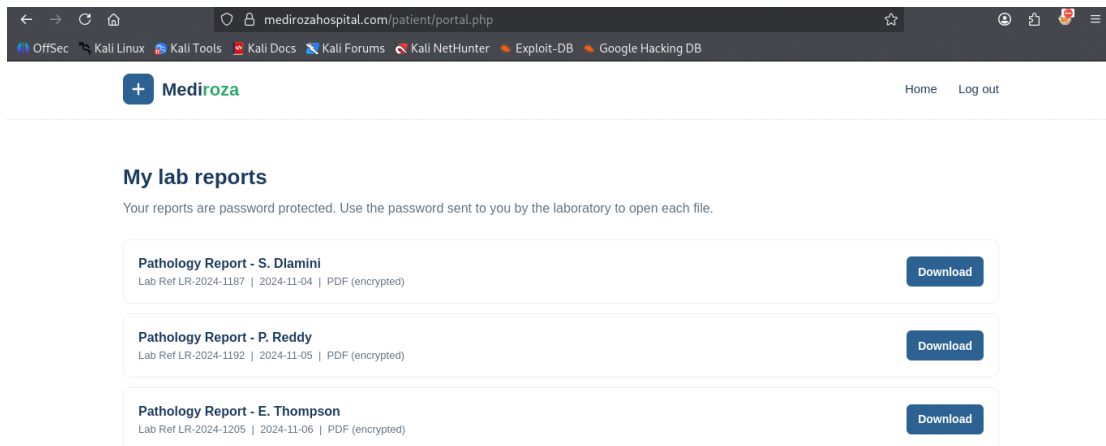
Evidence 07 : SQL injection testing against the authentication mechanism.



For responsible disclosure, exact exploit payloads and credentials are omitted from this public-facing report.

6.3 Restricted Area and Patient Reports

Following successful authentication bypass, access to the restricted laboratory-report area was demonstrated. Three confidential patient PDF reports were identified and retrieved for the next milestone.

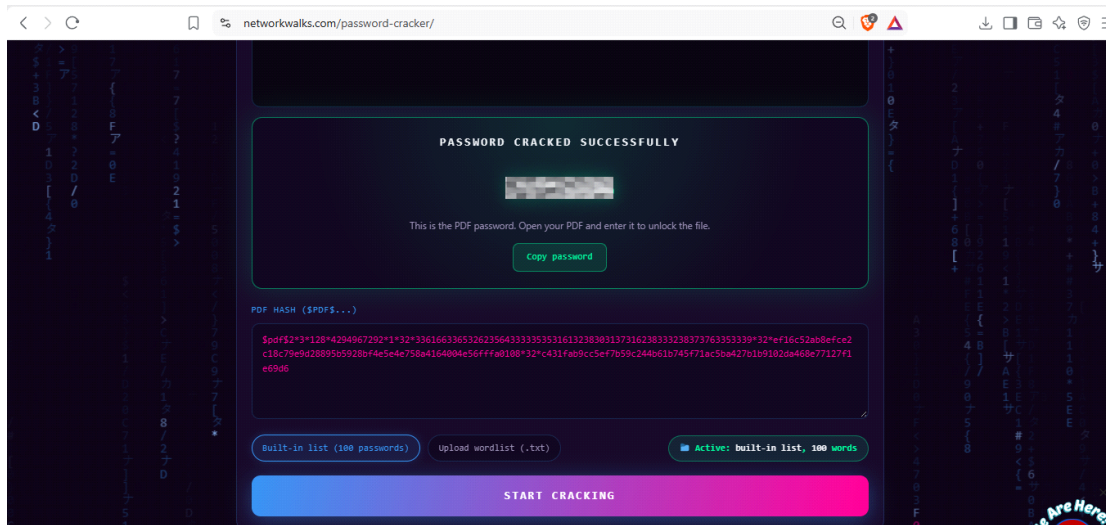


Milestone 1 result: successful access to the restricted area and retrieval of three patient laboratory reports.

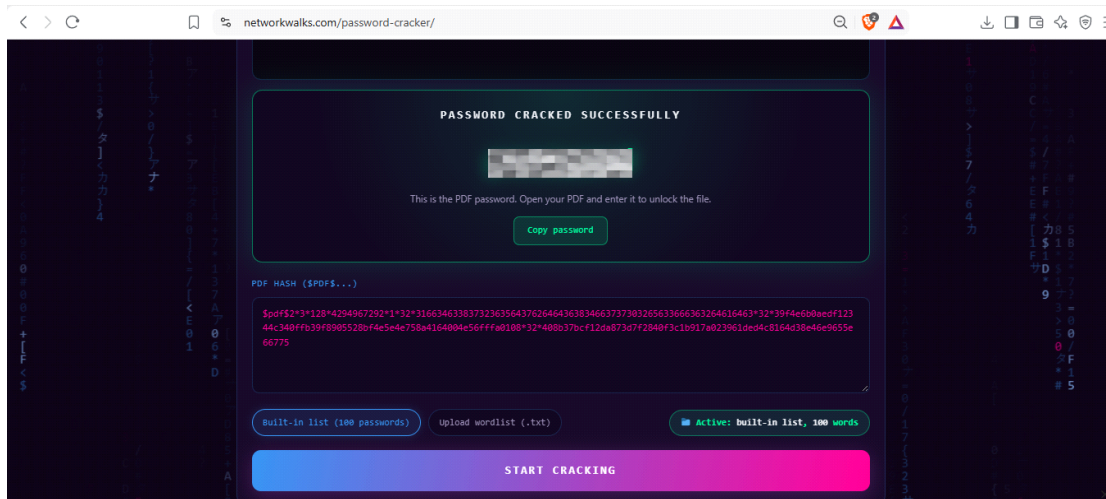
7. Milestone 2 – PDF Password Recovery

The three retrieved reports were protected by PDF password/encryption controls. Each file was analyzed separately because the project required that all three reports be recovered and the assessment instructions explicitly stated that a single recovery approach should not be assumed.

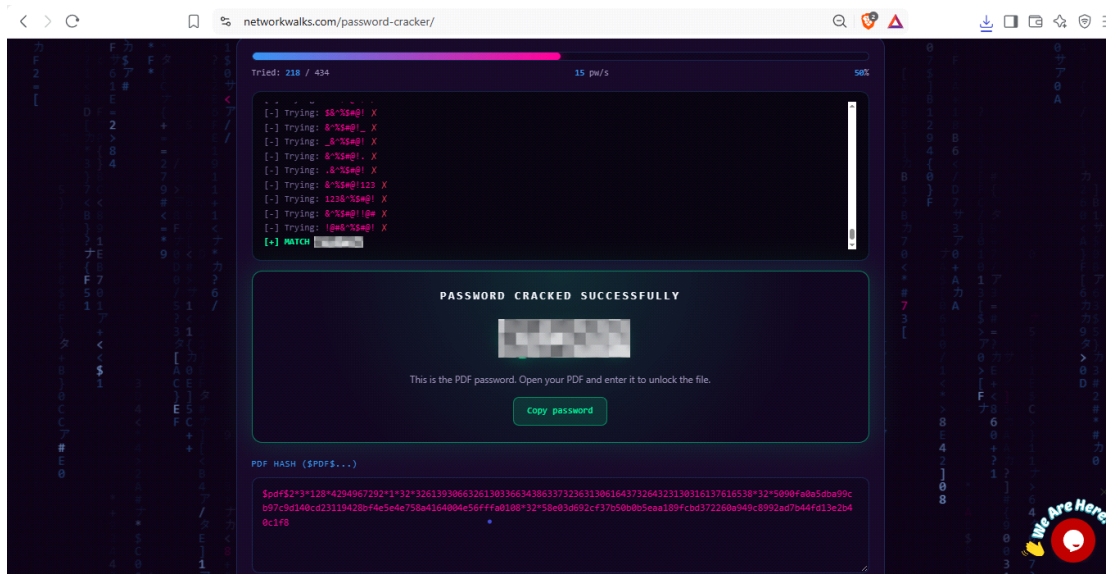
Evidence 09 : Password-recovery evidence for Patient Report 1.



Evidence 10 : Password-recovery evidence for Patient Report 2.



Evidence 11 : Password-recovery evidence for Patient Report 3.



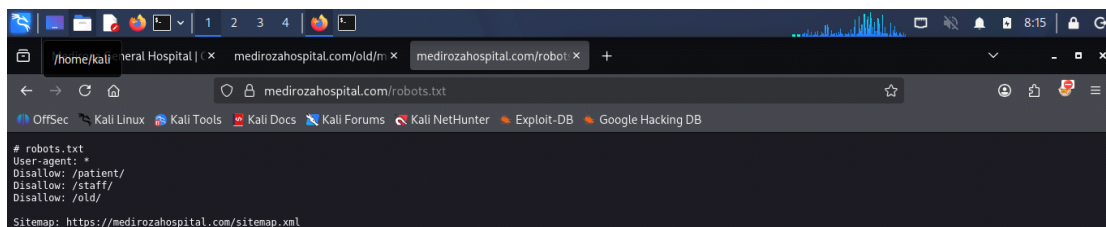
Milestone 2 result: password recovery was completed for all three encrypted patient reports, allowing their contents to be analyzed. Passwords and sensitive patient information are intentionally excluded from this report.

8. Milestone 3 – Critical Data Exposure

The third milestone expanded the investigation from the initially compromised area to additional resources exposed by the application. The analysis focused on information that could reveal hidden paths, obsolete content, backups, or other sensitive data.

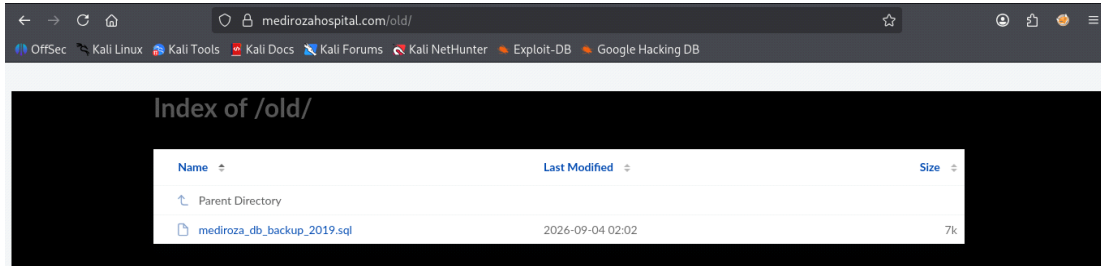
8.1 robots.txt Analysis

The target's robots.txt file was reviewed for references to directories or resources that could provide useful information about the application's structure. robots.txt is not an access-control mechanism; entries may still be directly accessible if server-side controls are absent.



8.2 Old Directory / Listing

Further investigation identified an older directory or listing that exposed additional resources. The finding was relevant because obsolete web content can remain accessible after it is no longer intended for public use.



8.3 SQL Database Backup Exposure

Analysis of the discovered resources led to an exposed SQL database backup. The backup was reviewed in the controlled environment to determine whether it contained confidential information.

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03
```

```
SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

```
--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff`
(`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099080',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198080',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
```

(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
 (21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
 (22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
 (23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
 (24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
 (25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
 (26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
 (27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297080',27000,'2019-09-02'),
 (28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
 (29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
 (30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');

UNLOCK TABLES;

--

-- Table structure for table `shareholders`

--

```
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

LOCK TABLES `shareholders` WRITE;

INSERT INTO `shareholders` (`id`,`shareholder\_name`,`share\_percent`,`shares\_held`,`share\_class`) VALUES

(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
 (2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
 (3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
 (4,'Reddy Family Trust',11.0,110000,'Ordinary'),
 (5,'Thabo Molefe',10.0,100000,'Ordinary'),
 (6,'Sarah Botha',9.0,90000,'Ordinary'),
 (7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),

```
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

The exposed data included employee salary information and hospital shareholder details. These records demonstrate a material confidentiality impact because the information was available through a resource that should not have been publicly accessible.

Sensitive patient information, employee records, shareholder details, credentials, and exact confidential values are intentionally not reproduced in this report.

9. Findings and Risk Assessment

The following findings summarize the vulnerabilities demonstrated during the engagement. Severity reflects the observed impact in the controlled training environment and should be treated as an assessment classification rather than a universal rating for every deployment.

ID	Finding	Severity	Primary Impact
F-01	SQL Injection in Authentication	Critical	Unauthorized authentication and access to restricted application functionality.
F-02	Exposed SQL Database Backup	Critical	Direct exposure of sensitive organizational information, including salary and shareholder data.
F-03	Weak Password Protection on Patient PDFs	High	Recovered protected reports after unauthorized acquisition, reducing the effectiveness of document-level protection.
F-04	Old Directory / Directory Listing Exposure	Medium	Disclosure of additional application resources and potentially obsolete content.
F-05	Sensitive Path Disclosure through robots.txt	Low	Disclosure of application paths that can assist reconnaissance; not an access-control bypass by itself.

10. Detailed Findings

F-01 — SQL Injection in Authentication

Severity: Critical

Evidence / Observation

Testing of the login functionality demonstrated that user-controlled input could influence the authentication query. Controlled SQL injection testing resulted in unauthorized access to the restricted application area.

Impact

Unauthorized users may bypass authentication and gain access to functions or data intended for authenticated users. In this engagement, the issue contributed directly to access to confidential patient laboratory reports.

Remediation

Use parameterized queries/prepared statements; eliminate dynamic SQL concatenation; validate input server-side; use least-privilege database accounts; add automated SQL injection testing to the secure development lifecycle.

F-02 — Exposed SQL Database Backup

Severity: Critical

Evidence / Observation

An SQL database backup was discoverable through exposed web resources and could be analyzed in the authorized environment. The backup contained sensitive organizational information.

Impact

Public exposure of a database backup can permit offline extraction of records without requiring normal application authorization. In this engagement, salary and shareholder information was recovered.

Remediation

Remove backups from web-accessible directories; store backups outside the document root; apply strict filesystem and web-server permissions; encrypt backups; implement backup exposure scanning and deployment checks.

F-03 — Weak Password Protection on Patient PDFs

Severity: High

Evidence / Observation

The three patient PDF reports retrieved during M1 were protected by passwords/encryption, but the assessment was able to recover access to each file using password-recovery techniques.

Impact

An attacker who obtains protected files may be able to recover their contents if passwords are predictable or otherwise weak. This reduces the effectiveness of document-level confidentiality controls.

Remediation

Use long, unique, randomly generated passphrases; avoid personal or predictable information; use modern PDF encryption settings; protect encryption keys separately; enforce secure document access through the application rather than relying only on PDF passwords.

F-04 — Old Directory / Directory Listing Exposure

Severity: Medium

Evidence / Observation

An old directory or listing was identified during M3 and exposed additional resources that were not necessary for normal public operation.

Impact

Obsolete resources can reveal application structure, historical files, backups, development artifacts, or other information that assists further attacks.

Remediation

Remove obsolete files; disable directory indexing; review web roots during deployments; conduct periodic content discovery and attack-surface reviews.

F-05 — Sensitive Path Disclosure through robots.txt

Severity: Low

Evidence / Observation

robots.txt contained information that helped identify paths of interest during reconnaissance.

Impact

robots.txt does not enforce access control. Disclosed paths can help an attacker focus enumeration and discover resources that should instead be protected by authentication and authorization controls.

Remediation

Do not place sensitive information in robots.txt; enforce authorization at the server/application layer; review publicly accessible paths and minimize unnecessary disclosure.

11. Attack Path Summary

The demonstrated attack chain can be summarized as follows:

1. Perform reconnaissance against the authorized target.
2. Identify the web application and authentication entry point.
3. Review the login implementation and test user-input handling.
4. Validate SQL injection in the authentication mechanism.
5. Gain access to the restricted application area.
6. Retrieve three confidential patient PDF laboratory reports.
7. Perform offline analysis and password recovery on the three reports.
8. Analyze additional web resources, including robots.txt and an older directory.
9. Identify and analyze an exposed SQL database backup.
10. Confirm exposure of employee salary and shareholder information.
11. Collect evidence and document remediation requirements.

12. Remediation Roadmap

Priority	Action	Recommended Owner
Immediate	Remove exposed database backups and verify that no backup/archive files are web-accessible.	Web/Infrastructure Team
Immediate	Correct the authentication SQL injection using parameterized database access.	Application Development Team
Immediate	Review access controls around patient reports and sensitive records.	Application/Security Team
High	Replace weak document passwords and improve document/key-management practices.	Application/Security Team
Medium	Remove obsolete directories and disable directory indexing.	Web/Infrastructure Team
Medium	Review robots.txt and ensure all sensitive paths have server-side authorization.	Web/Application Team
Ongoing	Perform periodic vulnerability scanning and manual penetration testing.	Security Team

14. Limitations

- The assessment was limited to the authorized target domain and the project rules supplied by Networkwalks.
- No denial-of-service testing was performed.
- No social engineering was performed.

- This report does not reproduce sensitive patient, employee, shareholder, credential, or password data.
- Severity classifications are based on the demonstrated training-environment impact and the evidence available during the engagement.

15. Conclusion

The authorized black-box assessment successfully completed the four project milestones. The investigation demonstrated an attack path beginning with reconnaissance and authentication testing, progressing through controlled SQL injection exploitation and retrieval of protected patient reports, and continuing into analysis of exposed resources and a database backup containing sensitive organizational information.

The results show the importance of secure database query handling, strong access control, secure document protection, removal of obsolete web content, and strict protection of backup files. Remediation should prioritize eliminating the authentication injection and preventing public access to database backups, followed by strengthening document protection and reducing unnecessary information exposure.

After remediation, the client should perform targeted retesting to confirm that each finding has been fully addressed and that related attack paths are no longer exploitable.

16. Responsible Disclosure

This report is intended for the authorized educational engagement. Sensitive patient information, passwords, credentials, exploit payloads, and confidential organizational records are intentionally omitted. Any public portfolio version should contain only redacted evidence and non-sensitive descriptions.

17. Reference

A publicly available Networkwalks B083 Week 4 repository was consulted as a documentation reference. It was used for general project-structure context only; the findings and evidence in this report are based on the assessment details supplied for this project.

Reference repository: [btk3d/NETWORKWALKS-B083-WK4-WEB-APP-PENTEST](#)

18. Author

Field	Details
Name	Pritesh Kalsariya
Role / Context	Cybersecurity Internship — Networkwalks B083
Project	Week 4 Web Application Penetration Testing

Target	Mediroza General Hospital — Authorized Training Environment
--------	---